

Multi-Factor Authentication (MFA) Policy – AWS Environment

(ISO/IEC 27001:2022 – Annex A 5.17)

Purpose

This policy enforces Multi-Factor Authentication (MFA) to strengthen access control and reduce the risk of unauthorized access to AWS resources.

Scope

This policy applies to:

- AWS root accounts
- IAM users
- Privileged roles within the Clinic's AWS Organization

MFA Requirements

1. Mandatory MFA Enforcement

- MFA is **mandatory** for:
 - AWS root account
 - IAM users with administrative or privileged access
 - Role switching between AWS accounts
- MFA must be enabled before access is granted.

2. Approved MFA Methods

- Virtual MFA devices (AWS Virtual MFA, Google Authenticator, Authy)
- Hardware MFA devices (where available)

3. Access Control & Role Switching

- Role switching requires MFA authentication.
- Permissions are granted following the principle of least privilege.
- Privileged access is reviewed periodically.

4. Monitoring & Evidence

- MFA enforcement is monitored through:
 - AWS IAM configuration
 - CloudTrail logs
- Evidence of MFA enforcement is retained as ISMS records in controlled S3 buckets.

5. Exceptions

- MFA exceptions require documented approval by the Security Manager.
- Exceptions must be time-bound and reviewed.

Compliance

Failure to comply with this policy may result in immediate access suspension.